OPA is a powerful tool for infrastructure policy, and Rego provides a flexible language for expressing logic over arbitrary data. However, when used specifically for access control, some teams—like ACME's product engineers—found they preferred a language designed expressly for authorization.

8.3 OpenFGA

As ACME's Customer Collaboration platform matured, so did its authorization challenges. The platform enabled employees and customers to share documents, leave comments, and delegate responsibilities across teams. The access rules were dynamic: some documents were visible to collaborators, others to managers, and many required fine-grained sharing, often with external partners. ACME needed a model that went beyond roles or attributes. They needed a way to represent and reason about relationships.

To facilitate this, they turned to OpenFGA (https://openfga.dev), an open-source project inspired by Google's Zanzibar system. Designed from the ground up for relationship-based access control (ReBAC), OpenFGA provides a scalable way to manage permissions using a graph of relationships between entities: users, documents, teams, roles, and more. Rather than write imperative policies, you define types and relationships in a schema, then express permissions as rules over those relationships. Authorization decisions are made by traversing this relationship graph.

For ACME, OpenFGA was a natural fit. Instead of hard-coding complex logic, the product team could model relationships between employees, customers, and documents (like the ones we explored in chapter 6 and modeled in figure 6.1) and let OpenFGA evaluate access dynamically.

8.3.1 How OpenFGA works

OpenFGA is based on the idea that access control can be represented as data: instead of writing complex policy code, you establish relationships between entities and determine permissions based on those relationships. In OpenFGA, the data is the policy.